DOCUMENT

04

API Reference

Endpoints, payloads, status codes and reason texts

Base URL for local development: `http://localhost:5000`. All bodies are JSON. Every endpoint except login needs the header `Authorization: Bearer <token>`; a missing or unknown token gives **401** with an empty body. Interactive OpenAPI docs are served by FastAPI at `/docs`.

1. Authentication

POST /api/auth/login

```
{ "username": "demo.manager", "password": "ChangeMe123!" }
```

Status	Body
200	`{ "token": "...", "username": "demo.manager", "role": "Manager" }`
401	`{ "error": "Invalid username or password." }`

POST /api/auth/logout

Returns **204**. Removes the token's session.

Demo accounts (local, in-memory, not real credentials)

Username	Role	Password
`demo.manager`	Manager	`ChangeMe123!`
`demo.director`	Director	`ChangeMe123!`
`demo.director2`	Director	`ChangeMe123!`
`demo.admin`	Admin	`ChangeMe123!`

2. Invoices

Method and path	Who	Description
`GET /api/invoices`	any signed-in user	List all; optional `?status=Draft|PendingApproval|Approved|Rejected` (case-insensitive). Unknown status gives 400
`GET /api/invoices/{id}`	any signed-in user	One invoice, or 404 (empty body)
`POST /api/invoices`	any signed-in user	Create a draft. Returns 201 with a `Location` header

Method and path	Who	Description
`POST /api/invoices/{id}/submit`	any signed-in user	Draft to Pending Approval
`DELETE /api/invoices/{id}`	Admin	204, or 404

Create body:

```
{ "customerName": "Acme School", "amount": 1250.50 }
```

Validation: customer name must not be blank; amount must be greater than zero, with at most 2 decimal places and 12 digits before the point. Invalid input returns 400 with a message and stores nothing.

Invoice JSON

```
{
  "id": "INV-2002",
  "customerName": "Ridgeview Education Consortium",
  "amount": 600000.0,
  "status": "PendingApproval",
  "createdAt": "2026-10-16T09:00:00+00:00",
  "decidedBy": null,
  "decidedAt": null,
  "decisionNote": null,
  "requiredApprovals": 2,
  "approvals": [
    { "username": "demo.director", "role": "Director", "approvedAt": "2026-10-16T10:00:00+00:00"
}
  ]
}
```

3. Approvals

Router access: Manager, Director and Admin. Other roles get 403 "You do not have permission to do that." The domain then decides who may really approve (Admin is refused with a reason).

POST /api/approvals/{invoiceId}/approve

Outcome	Status	Body
Approval recorded, more needed	200	invoice with `status: "PendingApproval"`, one entry in `approvals`, `requiredApprovals: 2`

Outcome	Status	Body
Approval recorded, invoice complete	200	invoice with `status: "Approved"`, `decidedBy` = final approver
Not allowed by the rules	**403**	`{ "error": "<reason>" }`, invoice unchanged
Invoice not pending	409	`{ "error": "Invoice INV-x is Approved; only pending invoices can be decided." }`
Unknown invoice	404	`{ "error": "Invoice INV-x was not found." }`
No or invalid token	401	empty

POST /api/approvals/{invoiceId}/reject

```
{ "reason": "Duplicate of INV-1001" }
```

Rejects a pending invoice (any amount, including a partially approved one). A blank or missing reason gives 400 "A reason is required to reject an invoice."

4. Refusal reason texts

These strings are asserted verbatim in the tests.

Situation	Reason
Role cannot approve	`Role {role} is not allowed to approve invoices.`
Manager above 50,000	`A Manager may approve invoices up to 50,000.00; this invoice is {amount} and needs a Director.`
Same user twice above 500,000	`{username} has already approved this invoice; invoices above 500,000.00 need two different approvers.`
Second approver is not a Director	`The second approver on an invoice above 500,000.00 must be a Director; {username} is a {role}.`

5. Status code summary

Code	Meaning in this API
200 / 201 / 204	Success
400	Bad input (`DomainValidationError`, invalid body, unknown status filter)
401	Missing or unknown session token

Code	Meaning in this API
403	Role not allowed at the router, or approval refused by the rules
404	Unknown invoice
409	Invoice is in the wrong state for the action
500	Unexpected error; no internal detail is returned

6. Example session (curl)

```
TOKEN=$(curl -s -X POST localhost:5000/api/auth/login -H 'Content-Type: application/json' \
  -d '{"username":"demo.manager","password":"ChangeMe123!"}' | python -c "import
sys,json;print(json.load(sys.stdin)['token'])")

# Manager on the 75,000.00 invoice: 403 with the Manager-limit reason
curl -i -X POST localhost:5000/api/approvals/INV-2001/approve -H "Authorization: Bearer $TOKEN"
```